



INTERNATIONAL TELECOMMUNICATION UNION

**TELECOMMUNICATION
STANDARDIZATION SECTOR**

STUDY PERIOD 2022-2024

SG17-TD1032
STUDY GROUP 17
Original: English

Question(s): 6/17 Geneva, 21 February - 3 March 2023

TD

Source: Editor

Title: Revised baseline text for X.sc-iot: Security Controls for Internet of Things (IoT) systems

Contact: Koji Nakao
NICT
Japan

Tel: +81-42-327-5821
E-mail: ko-nakao@nict.go.jp

Abstract: This TD provides a revised baseline text for X.sc-iot: Security Controls for Internet of Things (IoT) systems

Introduction

In the previous Q6/17 meeting, September 2022, a revised baseline text for X.sc-iot: Security Controls for Internet of Things (IoT) systems was published as [TD616](#).

During Q6/17 meeting, February 2023, [C320](#) was discussed, and the following modifications were accepted in the meeting.

Proposed modifications:

The main revised contents are as follows:

- Addition of keywords.
- Clarification and improvement of the text, especially from the perspective of vulnerabilities, etc.
- Revising parts that need editorial corrections.
- Addition of documents in bibliography.
- Etc.

Attachment:

Revised baseline text for X.sc-iot: Security Controls for Internet of Things (IoT) systems

Attachment

Draft Recommendation ITU-T X.sc-iot

Security Controls for Internet of Things (IoT) systems

Summary

IoT systems present particular challenges for information security in that they are highly distributed and involve a large number of diverse entities. This implies that there is a very large attack surface and a significant challenge for the information security management system (ISMS) to apply and maintain appropriate security controls across the whole system.

This Recommendation provides practical security guideline for three stakeholders of IoT systems such as IoT service provider, IoT service developer and IoT user, on IoT concept, risks of IoT systems and security controls.

Keywords

[IoT systems, Security controls, IoT security guidelines, IoT risk](#)

Table of contents

<u>1</u>	Scope	Er
	ror! Bookmark not defined.	
<u>2</u>	References:	4
<u>3</u>	Definitions:	4
<u>4</u>	Abbreviations and Acronyms:	4
<u>5</u>	Conventions:	4
<u>6</u>	IoT concept and risk in IoT systems	4
6.1	General	5
6.2	IoT Stakeholders (IoT Service provider, IoT Service developer, IoT user)	5
6.3	Reference Model (based on ISO/IEC 30141 (IoT RA))	5
6.4	Risks in IoT systems	
6.5	IoT life cycle	10
<u>7</u>	Security Controls	12
	7.1 Security controls for IoT service developer and IoT service provider	12
	7.2 Security controls for IoT	
	user	28
	6	
	Bibliography	27

Draft Recommendation ITU-T X.sc-iot

Security Controls for Internet of Things (IoT) systems

1 Scope

This Recommendation provides practical security guidelines for three stakeholders of IoT systems such as IoT service provider, IoT service developer and IoT user, on IoT concept, risks of IoT systems and security controls.

2 References

The following ITU-T Recommendations and other references contain provisions which, through reference in this text, constitute provisions of this Recommendation. At the time of publication, the editions indicated were valid. All Recommendations and other references are subject to revision; users of this Recommendation are therefore encouraged to investigate the possibility of applying the most recent edition of the Recommendations and other references listed below. A list of the currently valid ITU-T Recommendations is regularly published. The reference to a document within this Recommendation does not give it, as a stand-alone document, the status of a Recommendation.

- ISO/IEC 30141:2018, Information Technology — Internet of Things Reference Architecture (IoT RA)
- Recommendation ITU-T Y.2069 — Terms and definitions for the Internet of things

3 Definitions

3.1 Terms defined elsewhere

In this Recommendation, the terms given in ITU-T Y.2069, [ITU-T Y.4000](#) and ISO/IEC 27000 apply.

4 Abbreviations and Acronyms

IoT	Internet of Things
SaaS	Software as a Service
PaaS	Platform as a Service
IaaS	Infrastructure as a Service

5 Conventions

None

6 IoT concept and IoT risk

6.1 General

This clause provides a brief introduction to IoT concept and IoT risk which are useful in the context of security. Detailed information related to the following subclauses 6.2 and 6.3 is provided in ISO/IEC 30141:2018.

6.2 IoT Stakeholders (~~IoT Service provider, IoT Service developer, IoT user~~)

IoT domain can have a number of stakeholders like IoT service provider, IoT service developer, IoT user etc.

6.2.1 IoT service provider

The role of service provider is to manage and to operate IoT services. IoT service providers can also provide network connectivity. Security and security credentials of this connectivity needs to be addressed and maintained. Additionally, in case of cloud based IoT services, depending on the type of service offered from the data centre (SaaS, PaaS, IaaS), security management, multi-tenancy and tenant security and separation need be managed at different layers from the hardware up the stack to the application layers.

IoT service provider may provide end to end services or the part of it but should invariably provide IoT services over its platform.

6.2.2 IoT service developer

IoT service developers ~~are is~~ responsible for the design, implementation and integration of IoT services. IoT service developers can be further specialized, e.g. by taking on the role as of a design architect for IoT solutions or platforms/devices, as a designer developer and/ or implementer for of IoT applications and devices, as designer or implementer for IoT devices; IoT service developer will have multiple roles namely IoT device developer/ manufacturer, system integrator and the platform developer, application developer.;

~~One of the sub roles of IoT service developers is IoT device developer.~~ An IoT device developer integrates hardware and software securely into devices and applications, developing and maintaining device firmware that securely connects devices to an IoT-enabled platform.

IoT devices can either be operated and used directly by an IoT user or by an IoT service provider, and the technically same device can be used in various different IoT use cases. It is important for an IoT device developer to consider the security requirements of potential usage scenarios for the device in the design phase, in order to be able to offer devices which have the right set of functionality and features to fulfil their customers' need.

6.2.3 IoT-User

The IoT-User is the end-user of IoT services and can be categorized into human users and a digital users.

Human users ~~are is an~~ individuals, who uses IoT services. Digital users ~~are is a~~ non-human users ~~of the IoT systemservices including automation services; they can include automation services that act on behalf of human user.~~

6.3 Reference Model (based on ISO/IEC 30141:2018 (IoT RA))

- 3) IoT devices interact with the physical world through sensing and actuation. IoT devices include:
 - a) sensors, which observe a property of a Physical Entity and convert the observation into digital information;
 - b) actuators, which act on or change some properties of the Physical Entities based on digital instructions.
- 4) IoT devices communicate via a network. Many IoT devices communicate using a relatively short range and specialized proximity network, due to power and processing limitations.
- 5) Many other devices are able to communicate using wide area networks such as the Internet.
- 6) IoT gateways are commonly used in IoT systems. They form a connection between the local proximity network(s) and the wide area access network. IoT gateways can contain other entities and provide a wider range of capabilities. An IoT gateway often contains a management agent, providing remote management capabilities. The IoT gateway can contain a device data store, storing data from the associated IoT devices – this can either support local ("edge" or "fog") processing capabilities or be a means of dealing with intermittent communications networks. One or more analytics services can be supported by the IoT gateway, typically operating on data coming from the IoT devices or from the device data store. The IoT gateway can also contain applications – these can be control applications, where rapid local processing is required to direct actuators based on input from sensors.
- 7) Application and service sub-systems of various kinds exist in most IoT systems, with associated data stores. There is often a device data store, containing data derived from the IoT devices. There can be an analytics data store containing results from analytics services operating on device data and data from other sources. Analytics services of various types are usually present, processing device data and other data to derive insights, for example, monitoring performance. Process management is usually present, controlling processes associated with the IoT system. There are applications that reflect the capabilities of the IoT system itself. Finally, there are business services which provide capabilities related to the commercial use of the system, either by end users or by other external peer systems. The applications and services communicate with IoT gateways and IoT devices using the access network, while they communicate with each other using the services network.
- 8) The operation and management sub-system includes the device registry data store and an associated device identity service, which provides lookup capabilities for applications and services. There is a device management application, which provides monitoring and administration capabilities for the IoT devices in the system. There is an operational support system that provides various capabilities relating to the monitoring and management of the overall IoT system, including the offering of administration capabilities to users.
- 9) Access to the capabilities of the IoT system for users and peer systems is provided by the resource access and interchange sub-system, which provides controlled interfaces for service capabilities, for administration capabilities and for business capabilities. The capabilities provided depend on access control capabilities that vary depending on the user, requiring authentication and authorization before the capabilities can be used. Some of the capabilities can be provided through cloud service interfaces by implementations.
- 10) Users of the IoT system can include both human users and digital users. Human users typically interact with the IoT system using some kind of user device. The user device can take many forms – including smartphones, personal computer, tablet or a more specialized device. In all cases, some form of application interface is offered to the human user, where the capabilities are

supplied by an underlying application that interacts with the rest of the IoT system. Digital users interact with the IoT systems by means of service APIs controlled by the resource access & interchange sub-system autonomously. Both user devices and digital users communicate with the rest of the IoT system via the user network. For some IoT systems the user devices can interact directly with IoT devices or IoT gateways.

- 11) Peer systems, which can be other IoT systems or non-IoT systems, can be users of an IoT system and/or offer services to the IoT system. Peer systems interact with the IoT system through the user network – typically the Internet.

6.4 Risks in IoT systems

6.4.1 Introduction

~~Sub-clause 6.4~~ This sub-clause provides ~~features and various risk scenarios associated with the IoT systems, guidelines on how risks of IoT systems can be described and what the typical risks of IoT systems are.~~

Among widely varied applications of IoT systems, there are different contexts that determine risk scenarios, and hence different risks. A risk scenario is a description of conceivable security incidents, each of which consists of series of events and consequences. The descriptions are general. These should be used as references in developing the entity's own risk scenarios and risks that are modified and refined to adapt to the organization's business.

6.4.2 Features of IoT systems

IoT system senses movement or physical state of equipment or materials. It processes the sensed data and actuates to change the movement or physical states. ~~These can be called as features of IoT systems.~~ Given diversities in applications of IoT systems, it is impracticable to define a generally applicable set of features that fit to every IoT systems. As a practical way to describing features of IoT systems, "common features" and "specific features for application areas" can be identified.

IoT systems have the following common features:

- a) An IoT system has sensors that detect states or movement of equipment or materials;
- b) Data acquired by the sensor are securely transmitted over the network to an information system;
- c) The information system processes the data and generates controlling data;
- d) Controlling data are securely transmitted to actuators over the network; and
- e) Actuators translates the controlling data to the states or movement of equipment or materials.

In the case of "industrial plant and control systems", an application area of IoT system, have the following features in addition to the common features described above.

- a) IoT user is either human or digital (ISO/IEC 30141:2018);

- 1) A human user is an entity within an organization and acts within the scope of the organization's management;
 - 2) A digital user is a device that has interfaces with a sensor or an actuator;
- b) The states or movement of equipment or materials produced through actuators invoke consequences that have impacts on the IoT service developers and IoT service providers and on other entities.

NOTE – IoT systems categorized as industrial plant and control systems include:

- monitoring system for maintenance of equipment in a plant;
- remote management system of leased machines;
- control system for goods manufacturing; and
- control system of critical infrastructure operation, e.g., operation of electric power supply and water plant.

Use cases of these IoT systems are provided in [b-ISO/IEC TR 22417:2017], Information technology – Internet of Things (IoT) – IoT use cases.

6.4.3 Risk scenarios and risks in industrial plant and control systems

Risk scenarios of industrial plant and control systems can be derived from features of the systems. They contain series of risk sources, events and consequences.

- a) Circumstances that involve risk sources
 - 1) Operation of the IoT system relies upon or affected by:
 - quality, configuration and physical environments of information systems, networks and devices [and the software stack](#) that constitute the IoT system;
 - supporting utilities, e.g. electricity and telecommunications;
 - natural disasters;
 - conducts of persons with malicious intent;
 - unintended incorrect operation.
 - 2) Information systems, networks and devices of the IoT system can have vulnerabilities.
- b) Events
 - 1) Components of the IoT system are scanned and attacked through networks.
 - 2) Components of the IoT system are infected by malware.
 - 3) Operation of the IoT system is interrupted.
 - 4) The IoT system is intruded, abused and information is leaked.
 - 5) Components of the IoT system are abused as sources of attacks on the systems of external entities.

6) Systems and devices of external entities are attacked through networks.

c) Consequences

- 1) The industrial plant or control system halts its operation.
- 2) Systems of external entities are attacked.
- 3) The organization suffers business losses.
- 4) The organization suffers reputational damage.
- 5) System operations of external entities are affected due to attacks via the components of the organization.
- 6) System operations of external entities are affected due to dependence upon the organization's system operations.

Risk is defined as effect of uncertainty on objective (see definition of risk in ISO/IEC 27000). This requires that an objective need to be determined to identify risk. An objective is a target against which possibility and impacts of event and consequence is to be controlled. The objectives related to risk scenarios form a hierarchical structure as events and consequences do.

Risks are gaps between the objectives and estimated states of the system, i.e. gaps between targets and estimation of possibilities and impacts of events and consequences. Risks are identified in a hierarchical structure in parallel to the structures of events and consequences.

Once risks are identified, they are assessed. Each of the risks is judged if it needs treatment or is acceptable as it is. In the risk treatment process, relevant controls that affect risk sources, i.e. that modify possibilities or impacts of events and consequences, are determined to effectively mitigate the risks. Security controls given in 7.1 can be used to find necessary controls and also as a control set against which determined controls are compared, reviewed and justified.

6.5 IoT life cycle

IoT service is developed, provided, and used on the interrelationship of various stakeholders. Figure 2 shows the lifecycle of IoT service and the relationships among stakeholders.

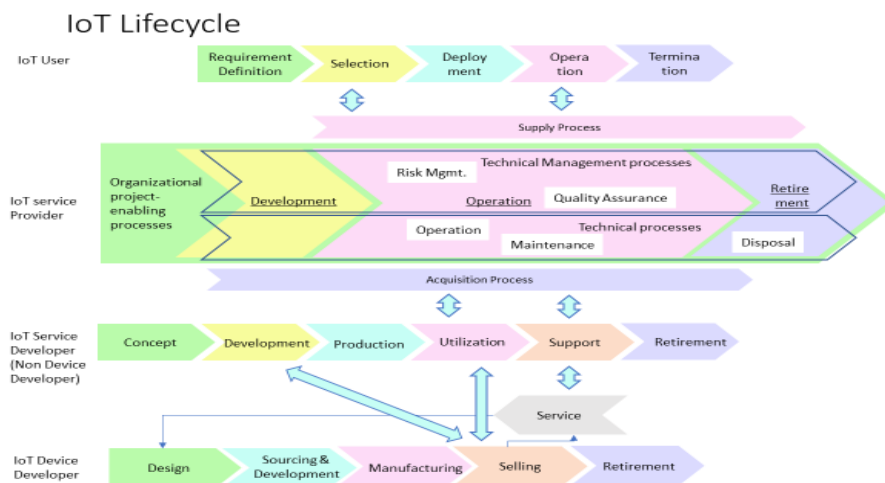


Figure 2 - IoT Lifecycle

IoT devices have product-specific lifecycles. the period of lifecycle is generally short. An IoT device developer should publish device information including security related information in the selling process such as contact details for reporting vulnerability, period for which the software updates will be provided. Also, with the firmware update of the device through the service, it can provide information about specification change. Since different devices can be subject to different security risks, therefore, devices can be classified depending upon the risk associated with the application.

An IoT service developer develops an IoT service with its security measures based on device information. The security information of the IoT service is disclosed at the stage where the service operates and is provided to users. Also, through system support, updates of the service and system are made. The IoT service developer also provides the IoT device ~~developer with~~ updates and other information related to the system. Firmware should be digitally signed to ensure the authentic updates. Secure onboarding of IoT devices on the platforms should manage device identity for the lifecycle by provisioning the secure device identities (e.g. using a PKI-based platform [b-ITU-T X.509]).

Tamper proof unexposed device identity should ensure the software assets of the device also helpful to manage to IoT device life cycle. The secure device identity, which can be generated during on boarding of IoT device by the service provider should be known to IoT device and respective IoT service provider only.

An IoT service provider procures the IoT service from the IoT service developer in the procurement process. At this stage, it obtains the security information of the IoT services.

These pieces of information are used in the development and operation of the IoT service.. In the Technical Management process, it is particularly important to reliably identify the critical information and maintain the quality of service. Specifically, the risk management process and the quality assurance process are key to information security in the IoT service. Also, it is necessary to

take measures such as vulnerability monitoring in the operation process and update the service in the maintenance process of the Technical process.

When the IoT system is replaced, the disposal process related to the system and system equipment becomes an important process in information security.

The IoT service is provided to IoT users through the supply process of the IoT service provider. In this process, information security specifications of the IoT service and updates are provided.

Based on the information disclosed in the supply process, IoT user selects an IoT service that meets the required specification. Information security related information is obtained and examined at this stage. Also, while using the IoT service, the IoT user applies the updates and uses other information provided by the IoT service provider to keep the level of information security.

7 Security Controls

7.1 Security controls for IoT service developer and IoT service provider

7.1.1 Policy for IoT security

Control

Policy for IoT security should be defined, approved by management, published, communicated to employees and relevant external parties and reviewed at planned intervals or if significant changes occur.

Purpose

To provide management direction and support for IoT security in accordance with business requirements, expectations of stakeholders and relevant laws and regulations in the risk environments.

Guidance

The IoT service provider or the IoT service developer should define its policy for IoT security demonstrating management commitment to IoT security.

The policy for IoT security should address requirements identified through understanding:

- a) organizational responsibilities in the provision of IoT services;
- b) internal and external stakeholders and their expectations;
- c) relevant laws and regulations; and
- d) risk environments.

The policy for IoT security should contain statements regarding:

- e) definition of IoT security;
- f) organizational objectives of IoT security;
- g) roles and responsibilities for IoT security within the organization (see 6.2).

The policy for IoT security should address [device security, vulnerabilities disclosure as well addressing and software/firmware updates for the complete lifecycle of the IoT devices. In addition to this](#), information security and other aspects which include quality of the IoT service ~~that are~~

relevant to IoT security should be also addressed. The policy for IoT security should also consider the consequences of incidents that affect safety of the internal and external stakeholders.

7.1.2 Organization of IoT security

Control

Roles and responsibilities for security of IoT should be defined and allocated.

Purpose

To establish a management framework to initiate and control the implementation and operation of IoT security within the IoT service provider or the IoT service developer.

Guidance

Allocation of roles and responsibilities for security of IoT should be done in accordance with the policy for IoT security.

Sub-roles of IoT service provider and IoT service developer should be allocated with IoT security roles and responsibilities.

The IoT security roles and responsibilities should include but not limited to those for:

- a) risk management activities;
- b) designing security measures for the IoT systems, devices and services;
- c) implementing and operating the security measures in the development and operation of the IoT systems, devices and services;
- d) managing secure supply chain and supplier relationships;
- e) awareness, education, training programs and workshop;
- f) incident management program and
- g) IoT security research.

Roles and responsibilities should be documented, disseminated within the organization and reviewed and updated as necessary.

7.1.3 Asset management

Control

Information, IoT devices and systems and their functions and operations to be protected should be identified.

Purpose

To identify assets of IoT devices and systems for designing appropriate protecting measures

Guidance

IoT service providers need to identify the assets related to the life cycle of the IoT service and document their importance. The life cycle of the IoT service should include creation, processing, storage, transmission, deletion, destruction. Documents related to the identified assets should be saved in a dedicated or existing inventory as needed.

Inventory of assets should be accurate, up to date, consistent.

The assets and their security including in the lifecycle of IoT devices and systems ~~may can~~ include the followings:

- a) software and firmware and their security implemented on IoT devices and systems;
- b) factory-set properties for initial use of IoT devices and systems;
- c) obtaining data by IoT devices and systems with secured credentials for human user and digital user.
- d) secure communication of ed-data in from motion from/to IoT devices and systems.

Editors' note: There was a suggestion to add "standard" in front of "factory-set properties" and "secure communication" to provide safer asset management. However, using the word "standard" is misleading, so if there is a better word, we will add it in b) and d) above. Contributions are expected to the next meeting.

e) for critical devices, secure execution should be implemented against side channel and fault attacks.

Implement an IoT device management to ~~managemanage~~ IoT device configurations and to always have knowledge to which physical assets IoT devices are paired.

7.1.4 IoT devices off-premises

Control

Security should be applied to the IoT devices located outside the IoT service provider's premises.

Purpose

To prevent loss, damage, theft or compromise of IoT devices and interruption to the operation of IoT services.

Guidance

When IoT devices are located outside the premises of the IoT service provider, following guidance should be considered to address associated risks:

- a) Ensure adequate physical protection of sensors and actuators. Cases of sensors and actuators placed in public areas should provide adequate resistance against opening to protect sensors and actuators from theft, destruction or manipulation.
- b) Ensure that locations of sensors and actuators are regularly checked, e.g. in the context of asset management activities.
- c) If only limited physical protection of IoT devices is possible, any users of the devices (e.g. consumers of sensor values) should be made aware of the limited trust level the devices provide.
- ~~e)d~~ Virtual device identifier should be implemented using geographical location. In case of change of device location virtual devices assumed to tampered and further system, get warning.

Editors' note: Since this document does not give a definition of Virtual device, that explanation needs to be added above d). We expect a contribution on the above addition for the next meeting, but if there is no clear proposal, we would like to delete the above d).

7.1.5 Secure disposal or re-use of equipment

Control

All items of equipment containing storage media should be verified to ensure that any sensitive data and licensed software has been removed or securely overwritten prior to disposal or re-use.

Guidance

Purpose

To prevent information leakage and malicious use of the IoT device and other equipment of the IoT system at its disposal or re-use.

Guidance

Storage media should be physically destroyed, or information stored in the media should be destroyed, deleted or overwritten using techniques to make the original information non-retrievable before disposal or re-use.

Disposal or re-use of IoT devices incur risks that software code or data is retrieved, analysed, modified and abused. Consequences of insecure disposal or re-use can be identity theft, unauthorized transaction, attacks on the IoT system, infringement of license terms and other incidents that affect the IoT users, IoT service developers, IoT service providers and other entities.

7.1.6 Learning from security incidents

Control

Knowledge gained from analysing and resolving IoT security incidents should be used to reduce the likelihood or impact of future incidents.

Purpose

To reduce negative effects of incidents in the provision and use of IoT services.

Guidance

Source of knowledge can be internal or external:

- a) When an incident handling by the IoT service developer or IoT service provider is closed, causes and consequences of the incident are identified.
- b) When an IoT security incident is reported by external authority, its relevance to the IoT system and service is examined and identified.

Based on the knowledge, IoT service developer and IoT service provider should modify as necessary:

- c) risk assessment, e.g. identification of risk sources and evaluation of risk;
- d) risk treatment, e.g. applied controls and their implementation;
- e) incident management processes; or
- f) vulnerability management processes, e.g. testing against known vulnerabilities before release of the IoT devices.

For example, knowledge of:

- newly announced software vulnerability can affect security measures of the IoT service (c));
- an attack on the IoT system can require modified or additional implementation of a control (d)); or
- an operational issue can indicate need for changing incident management process across IoT service provider and IoT users (e)).

Other information

[b-ISO/IEC 27035 (all parts)] provides guidelines for information security incident management, including lessons learnt, which are generic and applicable to all organizations. Guidance of this subclause highlights the aspects of lessons learnt relevant to IoT services.

7.1.7 Secure IoT system engineering principles

Control

Principles for engineering secure IoT systems that address designing and implementation of security functions, defence in depth and hardening of systems and software should be applied to the development of IoT systems.

Purpose

To ensure that security is designed and implemented in the development of IoT systems.

Guidance

The IoT service developer should have principles for engineering secure IoT systems.

The principles should require risk identification of IoT system considering the consequences that can affect the IoT users, the IoT service providers and other external entities on the network.

The risk identification should take different aspects of the IoT system. Examples of those aspects are:

- a) interfaces between the IoT system and external entities through networks;
- b) internal fraud in system operation and maintenance;
- c) quality issues of products and services acquired from external entities;
- d) physical access to the IoT system and devices; and
- e) changes in environmental conditions.

The principles should address the following areas of security measures to be considered in the IoT system development:

- a) security functions;
- b) hardening requirements of the system and software;
- c) requirements for defence in depth, i.e., layered design of security functions; and
- d) functions for monitoring and logging.

The principles should be applied to the development of IoT systems with the following security design concepts:

- a) Secure by default: This concept covers guidelines to choose the most secure options that are available during procurement and configuration, for example:
 - Minimizing attack surfaces;
 - [Hardware & Software assets using protection profile for critical and sensitive use cases](#);
 - Using a secure supply chain;
 - Using standards, best practices and reuse validated codes;
 - System hardening and operating with least privilege;
 - Reducing exposure time.

- b) Rigour in defence: This concept covers guidelines to ensure care and completeness in architecting the system, for example:
 - Defense in depth (multilayer);
 - Defense in breadth (variety), protect uniformly;
 - Compartmentalization of system (e.g. network segmentation);
 - Using encapsulation to manage access to functions;
 - Monitoring, detection and reporting of anomalies, including the use of honey pots;
 - Vulnerability assessment and pen testing;
 - Using a secure engineering approach;
 - Secure system lifecycle;
 - Patch diligently.
- c) Accountability: This concept covers guidelines to ensure care in granting and monitoring access to assets during operation. It also includes responsibility for reporting and mitigating known vulnerabilities, for example:
 - Connecting carefully and deliberately;
 - Ensuring the segregation of duties;
 - Establishing and protecting audit trails;
 - Practicing transparency (e.g. vendor disclosure, breach disclosure).
- d) Resiliency: This concept covers guidelines to ensure ability to resist or recover from a security incident, for example:
 - Designing for redundancy;
 - Managing availability;
 - Assumption of breach;
 - Failing securely (e.g. loss of devices or connectivity);
 - Managing vulnerability;
 - Backup and recovery;
 - Testing for scale;
 - Self integrity testing for critical IoT devices.

7.1.8 Secure development environment and procedures

Control

Secure development environment and procedures should be applied to the development of IoT systems.

Purpose

To avoid introduction of insecurity to IoT systems during development.

Guidance

A development environment includes people, processes, technology and facilities associated with a system development.

The IoT service developer should assess risks in individual IoT system development efforts and establish secure development environments considering:

- a) personnel working in the environment;
- b) physical, logical security, secure process, tools, methodologies used in development in software development life cycle applied and data handling processes;

~~applied development methodologies and software and data handling processes;~~

~~c) software assets security implementation against side channel attack and fault attack;~~

~~d) depending on the criticality and sensitivity, security testing should be performed by different people, persons, and organizations.~~

~~ge) use secure inspection and practice of evaluation for of~~ outsourced products and services;

~~fe)~~ physical and network environment; and

~~ge)~~ coexistence with other development and operational efforts.

The IoT service developer should determine the security of development environment and associated procedures to mitigate the risks. The procedures should be disseminated to individuals involved in the development efforts.

7.1.9 Security of IoT systems in support of safety

Control

Security principles in support of safety should be applied to the development of IoT systems.

Purpose

To support safety in IoT systems.

Guidance

In an IoT system, security events and controls can affect safety of the IoT system, e.g.:

- a) incorrect or corrupted control data can cause malfunctioning of the IoT system;
- b) security attack can cause safety function of the IoT system being inoperable; and
- c) implementation of a security control can affect performance of the IoT system and its safety functions.

The IoT service developer should consider hazards in the IoT system that can affect operation of the IoT system and its safety functions as possible consequences of security events.

The IoT service developer should also consider impacts of implemented security controls upon operation of the IoT system and its safety functions.

Other Information

There is a case that "safety" is prioritized over "security". This can be covered by the standards in ISO/IEC JTC1/SC41.

7.1.10 Secure connections to varied IoT devices

Control

An IoT system should be designed and implemented to ensure and maintain security in connecting varied IoT devices.

Purpose

To maintain security of IoT system which adopts IoT devices including those not necessarily verified by the IoT service developer or the IoT service provider.

Guidance

The IoT service developer and the IoT service provider design and implement an IoT system and require the IoT devices to meet defined specifications. The IoT devices are tested as components of the IoT system.

There is possibility that the IoT devices not yet tested as components of the IoT system by the IoT service developer or the IoT service provider are adopted. This is possible because testing all of the new models of supported devices can be impracticable. Or, IoT users, as consumers, can choose the devices available at market.

The IoT service developer and the IoT service provider should design and implement secure IoT system which is prepared for the situation. The IoT system can have the following capabilities as necessary:

- a) selectively connect the IoT device using a whitelist; or
- b) where applicable, obtain the specifications of the device, e.g. name of provider, model, year of production and conformance to relevant standard, when negotiating with the device for connection, and determine if the connection request is accepted or rejected, or confine the scope of function, service or information to be made available.

7.1.11 Verification of IoT devices and systems design

Control

Design and implementation of IoT devices and IoT systems should be verified.

Purpose

To ensure security and safety of the IoT device and IoT system.

Guidance

An IoT system is composed of IoT devices and other equipment. In the case where the IoT service developer or the IoT service provider acquires and integrates the IoT devices to build the IoT system, it should verify that the IoT devices and integrated IoT system function as intended.

The IoT service developer and the IoT service provider should:

- a) identify the IoT devices, functions and interfaces that need to be verified;
- b) plan verification testing; and
- c) perform the testing.

Conformance to an established standard can be considered in verification. Certification of the IoT device or equipment for conformance can be used as evidence supporting the verification.

7.1.12 Monitoring and logging

Control

States, events and network traffics of IoT devices and systems should be monitored and logged.

Purpose

To detect and trace abnormalities and incidents of IoT devices and systems.

Guidance

Monitoring and logging should be designed and implemented addressing the following aspects:

- a) functions and operations for monitoring and logging the states, events and network traffics of IoT systems and devices including sensors and actuators;
- b) functions and processes to analyse the logs;
- c) systems, human and organizational response triggered by detected abnormalities and incidents.

States, events and communications to be monitored and logged can include those of:

- a) security;
 - user authentication;
 - location of IoT devices;
 - changes to the IoT system configurations;
 - network traffics;
 - processors and memory usage;
 - indication of attacks and unauthorized accesses;
 - malfunction;
 - values which exceed normal ranges of sensing and actuating data;
 - values which indicate any unauthorized or unintended manipulation of sensing and actuating data;
- and
- b) reliability;
 - outage of IoT device or system; and
 - environmental conditions, e.g. temperature and moisture.

If an IoT device is able to self-locate its position, this should be used to monitor unintended transfer of the device.

Available resources for computing, storage and communication should be considered, and various needs for monitoring and logging should be prioritized when designing the functions for monitoring and logging. It should be noted that there are IoT devices which have limited resources and functions and not feasible for self-monitoring and logging. For these devices, monitoring and logging need be designed to be performed on servers or network nodes of the IoT system.

Logs of an IoT system can be collected in a logging system to facilitate management and operations. IoT devices located off-premises of IoT service provider can be vulnerable in maintaining the logs.

Clocks should be synchronized within an IoT system to allow consistent analysis.

Ensure adequate monitoring of IoT sensors and IoT actors is in place to early detect outages, malfunctions or values which exceed normal ranges or indicate any unauthorized or unintended manipulation.

Include IoT Elements in logging and monitoring activities to early identify any suspicious behaviour of IoT elements. This should include indications of unauthorized access as well as manipulations of sensor or actor data.

7.1.13 Protection of logs

Control

Logs for IoT device and system should be protected from leakage, destruction and unintended alteration.

Purpose

To ensure the capability and reliability of logging.

Guidance

Protection of the logs for IoT devices and systems should be designed and implemented. Measures to protect the logs can include:

- access control of the log file;
- access control of the device or system handling the log;
- physical access control of the facility housing the log media;
- enforcement of procedures for handling the logs;
- redundant configuration of the log;
- detection of destruction or alteration of the log, e.g. use of hashed values;
- encryption of the log;
- entries in the log with timestamps; and
- logs that should only be "read-only" for all except for the system process.

7.1.14 Use of suitable networks for the IoT systems

Control

Applied network and communication technologies for IoT and systems should meet the needs of communication function, capacity and security, and of function and performance of IoT devices.

Purpose

To use the network that meets security, performance and other needs of the IoT system.

Guidance

The IoT service developer and the IoT service provider should identify security, performance and other needs for the network. The needs can be those related to:

- a) geographical locations of the IoT devices and system;
- b) mobility of the IoT devices;

- c) restriction of IoT devices to be connected;
- d) confidentiality and integrity of information in transit;
- e) availability of the communication; and
- f) bandwidth of the network.

To meet the identified needs, the IoT service developer and the IoT service provider should consider to:

- a) choose adequate communication devices and services considering, e.g. service area, requirement for wireless communication, and bandwidth;
- b) apply encryption for transmitted information; and
- c) use gateway communication device to support IoT device with limited functions.

7.1.15 Secure settings and configurations in delivery of IoT devices and services

Control

IoT devices and services should be delivered with secure settings and configurations.

Purpose

To ensure security of IoT devices and services in delivery.

Guidance

The initial settings and configurations of IoT devices and services should be designed to contribute to the security of IoT users.

According to the features of the IoT device or service, relevant settings and configurations can be:

- versions and patches of software;
- open ports and network services; and
- access restriction to the functions and data of the service.

If the IoT device or service requires the IoT user a password, its initial value should be unique to the device or unique to the user of the service. The initial value should be securely informed to the IoT user.

7.1.16 Guidance for the IoT users on the secure settings and configurations

Control

Guidance on the settings and configurations of IoT devices and services including the needs to change initial values should be provided to IoT users.

Purpose

To ensure security of IoT devices and services in operation.

Guidance

Changes to the settings and configurations by the IoT users should be guided with supporting information that contribute to the secure use of the device or service.

The IoT users should be guided to change the initial password. Change of initial password may be procedurally mandated where appropriate.

7.1.17 User authentication

Control

Authentication function of users and IoT devices for accessing IoT systems and services should be implemented and applied.

Purpose

To protect information, IoT devices, systems and services from unauthorized access and other security breaches.

Guidance

Needs for authenticating the IoT users and IoT devices should be identified considering the operation of the IoT service and associated security risks. The needs can include those for authenticating:

- a) a human user for accessing the IoT device, system or service; and
- b) an IoT device for connecting to the IoT system.

Technologies applicable for implementing required level of authentication can be:

c) for human users, use of:

- 1) password authentication;
- 2) hardware credential, e.g. IC card; or
- 3) biometrics;

d) for IoT devices, use of:

- 1) [secure tamper proof](#) device identifier; or
- 2) trust anchor using hardware protection means.

The authentication function should be secure:

a) [Authentication should be performed with secure authentication protocols such as CHAP \(Challenge Handshake Authentication Protocol\) and PAP \(Password Authentication Protocol\);](#)

b) Password management should be secure against unauthorized use: initial delivery and changing procedures should be secure, strong password should be enforced.

c) Authentication credential should be adequately protected against unauthorized access regardless if it is stored in IoT device or system or in transit.

7.1.18 Applying updates during operation

Control

Mechanism for updating software and firmware of IoT devices and systems should be designed, implemented and operated.

Purpose

To ensure security for updating software and firmware of IoT device and IoT system.

Guidance

In the development of IoT service, mechanism for updating software and firmware of IoT devices should be designed and implemented as a basic [secure](#) function.

The mechanism for rolling back software and firmware should also be designed and implemented when failed its update.

In the utilization and support of IoT service, the software/firmware update package has its digital signature, signing certificates & signing certificate chain verified by device, before update process begins.

~~Cryptographic keys used to protect the integrity and confidentiality of updates should be securely managed and properly operated using techniques such as digital signatures. Cryptographic keys used for update integrity protection and confidentiality should be securely managed and appropriately operated.~~

When updates are conducted over the air (OTA), the updates should be performed over encrypted communication channels.

When device cannot verify authenticity of updates itself, it should roll back to last known good configuration that was stored on the device.

Updates using OTA should either succeed completely or fail in a recoverable manner. In the case of a failed update, the device should be rolling back to the last known good configuration, and it should have no ability to disable a device's connection to the update server.

7.1.19 Sharing vulnerability information

Control

Vulnerabilities of IoT devices, systems and services should be monitored and informed to the IoT users and relevant parties along with associated risks.

Purpose

To ensure security for monitoring IoT risks and sharing relevant IoT vulnerabilities among relevant stakeholders.

Guidance

Vulnerability information should be collected, analysed and disseminated to relevant IoT stakeholders, and finally necessary measures such as firmware updates (see 7.1.18) need to be taken.

In the case of IoT firmware updates, the update version should be obtained via a reliable route, such as downloaded from a reliable website such as an IoT device manufacturer.

Measures for monitoring and sharing IoT vulnerabilities can include:

- a) Collect and analyze vulnerability information that occurred during the operation of IoT systems and services.
- Understanding and managing the basic configuration information of IoT devices / systems and services provided by the company;

- Investigating the impact of the obtained vulnerability information on the IoT devices / systems and services provided by the company;
- Select information that needs to be transmitted out of information that is anticipated to have external impacts.
- b) Consider a mechanism that feeds back vulnerability information obtained by stakeholders in contact with the site to IoT device manufacturers and IoT system / service providers.
- c) Collect and analyze information sent by IoT device manufacturers, public organizations, ISACs (Information Sharing and Analysis Center), etc.

7.1.20 Notification of risks and required actions

Control

Risks and required actions related to the IoT system and service should be informed to IoT users.

Purpose

To improve security in the use of the IoT system and service.

Guidance

Risks and required actions to mitigate the risks should be informed to the IoT user before commencement of service delivery.

Risks and required actions can include those related to:

- a) supported IoT devices;
- b) supported versions and modification levels of software;
- c) requirements for initial set-up and user registration;
- d) secure use of the IoT system and service;
- e) security risks caused by inappropriate use of the IoT system and device, and
- f) contact point of the IoT service developer and the IoT service provider accessible during operation.

This information can be provided as part of general information for the use of IoT system and service in a form of document for the IoT system or service, e.g. user manual or an attachment to the license agreement.

7.1.21 Security measures adapted to the lifecycle of IoT system and services

Control

Security measures of the IoT system and service should be adapted to and kept during the stages of the lifecycle, including their development, operation, maintenance and destruction.

Purpose

To maintain security of IoT system and service throughout the lifecycle.

Guidance

During development, security measures of the IoT system and service should be designed and implemented in conformance to the secure IoT system engineering principles (7.1.7 Secure IoT system engineering principles) and relevant controls given in 7.1.8 to 7.1.14.

To prepare for operation, maintenance and destruction, the IoT service developer and the IoT service provider should identify relevant entities including IoT users and other IoT service developers and providers with which security information should be exchanged.

When the IoT system and service are installed and operated, secure configurations and settings should be continually enforced. It should be supported by sharing information about:

- a) hardening of the IoT system and service;
- b) use of secure passwords or other user credentials;
- c) disclosed vulnerabilities;
- d) software updates;
- e) security alerts and workarounds; and
- f) termination of technical support for devices and software by the vendors.

When the IoT system, service or components terminate the lifecycle:

- g) confidential information should be securely destroyed or returned to its owner; and
- h) the IoT users should be informed of the process to be followed at termination of the IoT system and service.

7.1.22 Guidance for IoT users on the proper use of IoT devices and services

Control

IoT users should be provided with guidance on the proper use of IoT devices with risks and undesirable effects of IoT system and service that can be derived from improper connections or use of IoT devices.

Purpose

To make the IoT users aware of the security risks in the use of IoT devices, and to ensure implementation of security measures.

Guidance

The IoT service developers and the IoT service providers have responsibilities in security that commensurate to their respective roles in the development and provision of the IoT service. In the use of the IoT devices, some of the security measures need to be carried out by the IoT users. To support the IoT users, the IoT service developers and the IoT service providers should provide information about the risks and consequences, and guidance for proper use of IoT devices.

The guidance can include:

- a) devices and configurations verified for use in the IoT system and service;
- b) necessary security updates for software;
- c) security settings for WiFi; and
- d) criteria for qualified passwords.

Risks and consequences provided to the IoT users can include but not limited to:

- a) malware infection of the IoT device;

- b) leakage of the IoT user's personal information;
- c) leakage of business information; and
- d) malicious use of the IoT device for DoS attack.

7.1.23 Demarcation of responsibilities among interested parties

Control

Roles of IoT service developer, IoT service provider and other interested parties in security of IoT system and service should be determined and agreed among relevant parties.

Purpose

To ensure security of IoT system and service that involve entities participating in the provision and use of IoT system and service.

Guidance

The roles of IoT service developer and IoT service provider in security should be determined along with their roles in IoT service provision. The IoT service developer should have security roles in developing, implementing, testing and integrating the IoT service. The IoT service provider should have security roles in managing and operating the IoT service. Sub-roles of the IoT service developer and the IoT service provider should be allocated with security roles as necessary.

The security roles should be communicated to relevant parties including the IoT users. The communication can be in the form of:

- a) service specification provided to the IoT users; or
- b) agreement between the parties in the supply chain for the IoT service.

The security role of the IoT user can be enforced in the initial set-up procedure requiring an action as confirmation of the security role.

7.1.24 Management of vulnerable devices

Control

Vulnerable IoT devices should be detected, recorded, and alerts provided to IoT users and administrators of these devices.

Purpose

To maintain IoT devices to be secure.

Guidance

The IoT service provider should develop and establish mechanisms for:

- a) detecting and recording vulnerable IoT devices;
- b) providing alerts to the IoT users and administrators of the devices;

c) the platform can have the ability to detect and resolve vulnerabilities. If the vulnerability cannot be resolved, the platform should report this to the manufacturer/user; and

d) as there are large number of IoT service providers, a central entity to ensure the trust among the users should be considered. This can facilitate the IoT service providers in resolving the

vulnerabilities through IoT device manufacturers/researchers. This central entity can be named as trust center.

During operation, IoT devices should be monitored continually to detect malfunctional behaviors. Once any suspicious behavior is detected, it should be recorded, and alert should be noticed to the IoT users and administrators.

Include IoT devices in vulnerability management processes to ensure identification and adequate handling of any vulnerability present in devices.

7.2 Security controls for IoT user

7.2.1 Contacts and support service

Control

IoT device and service that have no contacts for support service should not be chosen.

Purpose

To support IoT user.

Guidance

If there is no information about manufacture or sales contact of product support for the IoT device, the IoT service using such IoT device is not reliable. The device may contain "Trojan" and should not be selected in the IoT service. IoT user should pay attention to the credit of the device provider and service provider.

7.2.2 Initial settings of IoT device and service

Control

Initial settings of IoT device and service should be applied correctly.

Purpose

To ensure initial settings of IoT devices and service.

Guidance

Initial settings such as "factory-set ID" and "password" for IoT devices are thought to be known to the public since the user's manual is publicly available. The factory-set ID and password should be reset by user. The new setting should not be the same as the original, should not be shared with other IoT device setting, and should not be easily guessable and not on the list of popular ID/password list available on the internet.

Ensure any default authentication credentials are changed before a IoT device goes into service

7.2.3 Turning off the switches of unused devices

Control

Device should be turned off if it is no more used.

Purpose

To reduce the risks caused by IoT device that is no longer used.

Guidance

IoT devices, that are no longer in use but are still connected to the Internet, can be taken over and used without noticing via the Internet by unauthorized third parties. To reduce the potential risk of IoT devices, IoT devices that are no longer in use should be turned off.

7.2.4 Secure disposal or re-use of IoT device

Control

Data and licensed software stored in IoT device should be removed or securely overwritten prior to disposal or re-use.

Purpose

To ensure for secure disposal or re-use of IoT devices.

Guidance

Information collected and used during IoT service operation may be stored in the IoT devices. To avoid information leakage to other users, the information stored in the IoT devices should be deleted, or the IoT devices should be reset to the factory original condition before disposing or reusing the IoT devices.

Bibliography

[b--ISO/IEC TR 22417:2017] ISO/IEC TR 22417:2017, *Information technology – Internet of Things (IoT) – IoT use cases (if we remove this TR from the main body text)*

[\[b-ITU-T X.509\] Recommendation ITU-T X.509 \(10/2019\) and cor.1 \(10/2021\) Public-key and attribute certificate frameworks](#)

[b--ISO/IEC 27001] ISO/IEC 27001, *Information technology – Security techniques – Information security management systems – Requirements*

[b--ISO/IEC 27035(all parts)] ISO/IEC 27035 (all parts), *Information technology – Security techniques – Information security incident management*

[\[ITU-T Y.4000\] Recommendation ITU-T Y.4000/Y.2060 \(2012\), Overview of the Internet of things](#)
